SIMATS ENGINEERING

Saveetha Institute of Medical and Technical Sciences

CSA6303 - Threat Intelligence and Network Security

A2 - Malware Analysis Assignment

Assessment Answers

Subject	Threat Intelligence
Course Outcome	CO3
Total Marks	50
Questions	10 (all compulsory)
Marks per Question	5
Reg. No	192465038
Name	THAMMISETTI RAJU
Faculty	Dr. V. Parthipan
Slot	A

Instructions

Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

CO3: Perform threat analysis using intelligence models and utilize industry tools for monitoring and detection.

Code of Conduct

I THAMMISETTI RAJU / 192465038 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

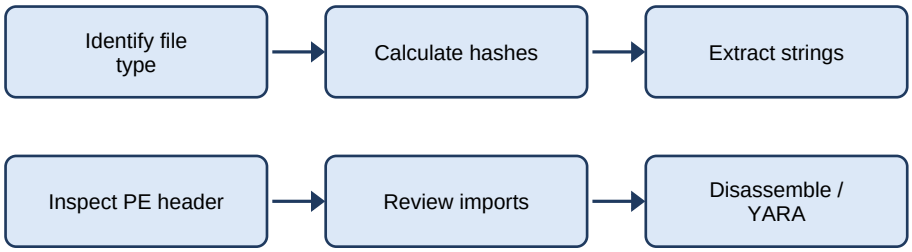
Signature of Student: _____

Question 1: Malware Analysis Using Static Techniques [5]

Scenario: a suspicious executable arrives by phishing email and must be examined without running it.

Definition. Static analysis examines a file's code, structure and metadata *without executing it*. It is fast and safe, and gives a first risk assessment before any dynamic testing.

Static analysis steps



Technique	Tools	What it reveals
File identification	file, TrID, hex editor	True type via magic bytes (MZ for PE), e.g. a .pdf.exe double extension or a fake icon
Hashing (MD5, SHA-256)	sha256sum, HashMyFiles	Unique fingerprint; look it up on VirusTotal or MalwareBazaar to see if it is already known
Strings	strings, FLOSS	URLs, IP addresses, file paths, registry keys, commands, ransom notes, hard-coded passwords
PE header and sections	PEStudio, CFF Explorer, DIE	Compile time, section names, high entropy (above about 7) suggests packing or encryption (UPX), abnormal section sizes, missing or fake digital signature
Imported functions (API)	PEStudio, Dependency Walker	Intent of the program (see below)
Disassembly	Ghidra, IDA, Cutter	Program logic, decryption routines, C2 addresses
Rule matching	YARA, ClamAV	Matches known malware family patterns

Suspicious API imports: *VirtualAllocEx, WriteProcessMemory, CreateRemoteThread* (process injection); *URLDownloadToFile, InternetOpenUrl* (download or C2); *RegSetValueEx* (persistence); *SetWindowsHookEx, GetAsyncKeyState* (keylogging); *CryptEncrypt* (ransomware); *IsDebuggerPresent* (anti-analysis).

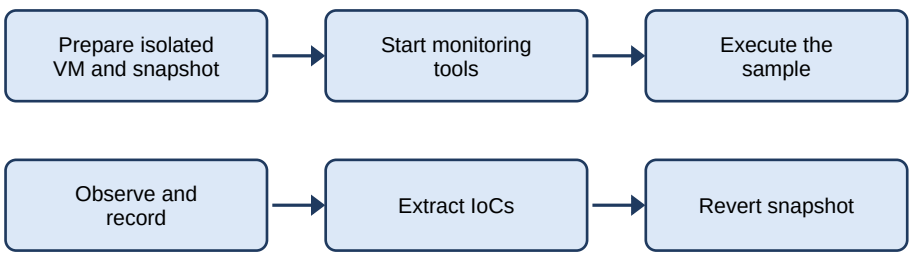
Risk assessment. A known-bad hash, packed sections, unsigned binary, injection plus network APIs and embedded suspicious URLs together indicate high risk. **Limitations:** packed or obfuscated code hides content and runtime behaviour is not seen, so dynamic analysis follows.

Question 2: Malware Analysis Using Dynamic Techniques [5]

Scenario: a downloaded program may modify system files and contact an external server.

Definition. Dynamic analysis runs the sample in a controlled sandbox and records what it actually does.

Dynamic analysis workflow



Safe lab set-up

- Virtual machine (VMware / VirtualBox) with a clean Windows image and a **snapshot** to restore after each run.
- Network isolated (host-only). **INetSim / FakeNet-NG** simulates DNS, HTTP and SMTP so the malware's requests can be seen without reaching the real internet.
- No shared folders or clipboard, no real credentials, and the VM is not connected to the corporate network.

Monitoring and observations

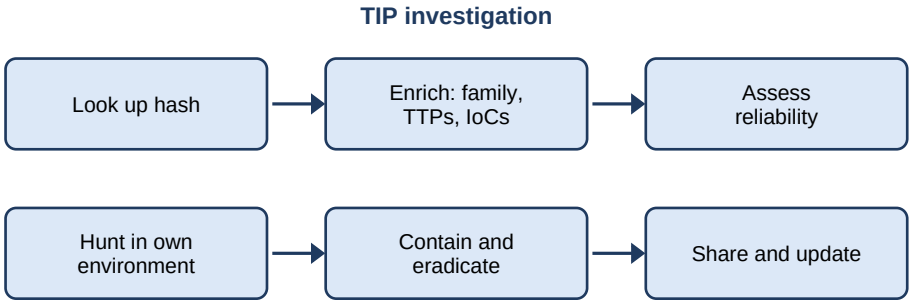
Area	Tool	Behaviour looked for
Processes	Process Monitor, Process Explorer	New or injected processes, parent-child chains, dropped files
File system	Process Monitor	Modified or deleted system files, files created in AppData or Temp
Registry	Regshot, Autoruns	Run keys, services, scheduled tasks created for persistence
Network	Wireshark, Fiddler, FakeNet-NG	DNS lookups, C2 IP and domain, ports, beaconing interval, data uploads
Automated sandbox	Cuckoo, any.run, Joe Sandbox	Full behaviour report with screenshots and MITRE mapping

Indicators of Compromise (IoCs) obtained

File hashes and dropped file names or paths; registry keys and mutex names; created services or tasks; C2 domains, IP addresses, ports and User-Agent strings; unusual process names. These are shared as STIX/MISP indicators and used in firewall, SIEM and EDR rules. **Caution:** some malware detects virtual machines or sleeps to evade sandboxes, so analysts mask VM artefacts and extend run time.

Question 3: Malware Investigation Using a Threat Intelligence Platform [5]

Scenario: a suspicious file's hash matches a known malware family in a threat-intelligence platform (TIP).



1. Investigating with threat-intelligence sources

- Query the hash in **VirusTotal, MISP, AlienVault OTX, MalwareBazaar, IBM X-Force, Recorded Future** and note detections, family name, first-seen date and file behaviour.
- Gather related IoCs (C2 domains, IPs, other hashes, mutexes) and the attacker's TTPs from MITRE ATT&CK; identify the campaign or threat actor and targeted industries.
- Pivot on these indicators to search the company's SIEM, EDR, DNS and proxy logs to find other infected machines.

2. Assessing the reliability of the information

Criterion	Check
Source reputation	Vendor or community feed with a good track record; use the Admiralty scale (source A-F, information 1-6)
Corroboration	Same indicator confirmed by two or more independent sources
Timeliness	Indicators age quickly (IPs and domains get reused); check first/last seen
Context and confidence score	Is there analysis, behaviour and a confidence rating, or only a bare hash?
False positives	Shared hosting, CDNs or benign tools flagged; validate with own analysis
Sharing level	Respect TLP markings (White, Green, Amber, Red) when sharing

3. Recommended containment measures

- Isolate the infected computer (EDR network quarantine); do not power off if memory evidence is needed.
- Block the malicious IPs, domains and hashes at firewall, proxy, DNS and EDR; reset exposed user and admin credentials.
- Scan all endpoints for the IoCs; remove the malware and its persistence; re-image if needed; patch the exploited vulnerability.
- Preserve evidence, document in the incident ticket, notify management, and feed new IoCs back to the TIP.

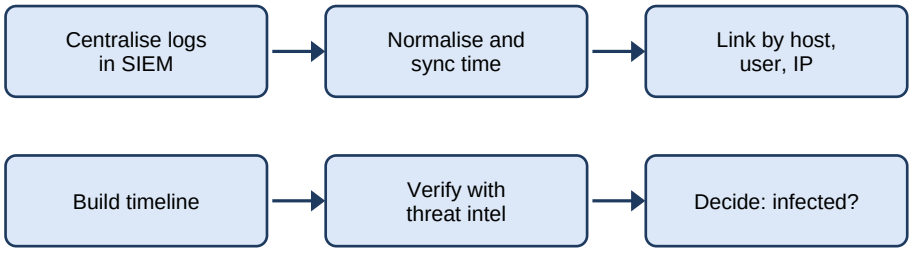
Question 4: Malware Detection Through Data Collection and Correlation [5]

Scenario: a university sees unusual processes, suspicious DNS requests and unexpected outbound connections on several computers.

Idea. One log source may look harmless; correlating several shows the full attack chain.

Data source	What to collect	Malware evidence
Endpoint logs (Sysmon, Windows events, EDR)	Process creation, command line, parent process, file and registry changes, hashes	Unknown or renamed processes, PowerShell with encoded commands, persistence entries
DNS records	Queried domain, client IP, response, time	Newly registered, random-looking (DGA) or very long domains, many NXDOMAIN, regular queries (beaconing)
Firewall / proxy logs	Source and destination IP, port, bytes, action	Connections to rare external IPs, odd ports, large uploads at night
File hashes	SHA-256 of suspicious files from endpoints	Matches in VirusTotal / MISP confirm the malware family

Correlation steps

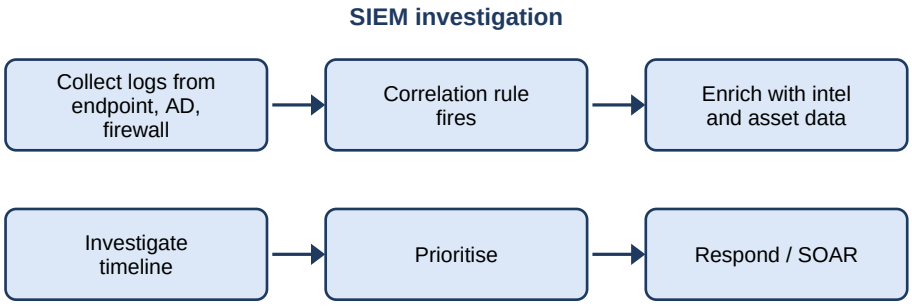


- Join events on the **host/IP, user, timestamp and hash**. Example timeline: 09:02 *update.exe* starts on PC-14 (Sysmon), 09:02 DNS query to *x7qk2.biz*, 09:03 firewall shows PC-14 connecting to 185.x.x.x:443, repeating every 60 s.
- Check the hash and domain against threat intelligence; count how many other computers show the same process or domain.

- **Conclusion rule:** process anomaly + malicious domain + matching outbound connection on the same host in a short time window means the computer is very likely infected. Isolate and begin response.

Question 5: Malware Investigation Using SIEM Tools [5]

Scenario: a SIEM raises alerts for suspicious process execution, repeated failed logins and unusual network connections from the same workstation.



1. Correlating the events

A correlation rule joins events by workstation and time: *suspicious process (e.g. PowerShell from Office) + 5 or more failed logins (credential guessing or lateral movement) + new outbound connection to a rare IP, all within 30 minutes*. The SIEM merges these separate alerts into one incident for the same host, which is far stronger evidence of malware than any single alert.

2. Investigating the infection

- Open the host's timeline and review the process tree, command line, hash and user; check the hash in the threat-intelligence feed.
- Trace failed logins: source host, target accounts, and whether any later succeeded; look for movement to servers.
- Examine the destination IP/domain reputation, bytes sent and beaconing pattern; search the whole network for the same IoCs to find other infected hosts.

3. Prioritising the incident

Factor	Reason for high priority in a financial institution
Asset criticality	Workstation of a teller, finance or admin user with access to payment systems
Confidence	Multiple independent events and a threat-intelligence match
Kill-chain stage	C2 and credential attacks mean the attacker is already active
Impact and compliance	Possible fraud, data breach and regulatory reporting (PCI-DSS, RBI/SEBI guidelines)

The incident is rated **High/Critical**, assigned to the Tier 2 analyst, the workstation is isolated, and the account is locked. SOAR can automate blocking and ticketing.

Question 6: Malware Detection and Log Analysis Using Splunk [5]

Scenario: Splunk monitors endpoint and network logs; malware may be contacting an external command-and-control (C2) server.

Approach. Ingest logs with the Universal Forwarder (Sysmon, DNS, firewall, proxy), then hunt using the Search Processing Language (SPL).

1. Search relevant logs and find rare or suspicious destinations

```
index=proxy OR index=firewall
| stats count dc(src_ip) as hosts by dest_domain
| where hosts<3
| sort count
```

2. Identify beaconing (regular, repeated communication)

```
index=firewall action=allowed
| sort 0 src_ip dest_ip _time
| streamstats current=f last(_time) as prev by src_ip dest_ip
| eval delta=_time-prev
| stats count avg(delta) as avg_s stdev(delta) as sd by src_ip dest_ip
| where count>20 AND sd<5
```

A low standard deviation of the time between connections means automated, periodic traffic (for example every 60 seconds).

3. Other suspicious patterns

```
index=dns | eval len=len(query) | where len>50
| stats count by src_ip, query

index=sysmon EventCode=3 NOT Image="*\\chrome.exe"
| stats count by host, Image, DestinationIp
```

The first search shows possible DNS tunnelling or DGA domains; the second shows unusual programs making network connections.

4. Correlation and enrichment

Use *lookup* with a threat-intelligence IoC list to tag known-bad domains and IPs, then join process-creation events (Sysmon EventCode 1) with network events (EventCode 3) on host and time to link the suspicious process to the C2 connection. Add context with user and asset lookups.

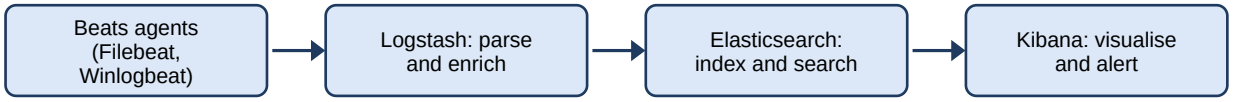
5. Documenting evidence

- Save searches as reports; create a scheduled alert for future matches and a dashboard of beaconing hosts.
- Export result tables (CSV/PDF) and screenshots with timestamps, host, user, process, hash, destination and bytes.
- Record the investigation timeline and IoCs in the incident ticket and keep the raw logs for chain of custody.

Question 7: Malware Investigation Using the ELK Stack [5]

Scenario: an e-commerce company uses Elasticsearch, Logstash and Kibana; repeated connections to suspicious domains and unusual file activity are observed.

ELK pipeline



Stage	Role in malware investigation
Log collection	Filebeat ships web-server and firewall logs; Winlogbeat/Auditbeat ship endpoint events (process, file integrity); Packetbeat and DNS logs show network activity.
Processing (Logstash)	Input, filter and output pipeline: *grok/dissect* parse fields, *date* fixes timestamps, *geoip* adds location, translate/enrichment adds threat-intel tags, then data is mapped to the Elastic Common Schema (ECS).
Storage and search (Elasticsearch)	Indexes all events for fast full-text and field searches, for example all hosts that queried a suspicious domain.
Visualization (Kibana)	Discover for queries; dashboards with top rare domains, connections over time, processes per host, geo-map of destinations; spikes and periodic patterns stand out visually.
Correlation	EQL sequence queries and detection rules (Elastic Security) link events; Watcher/Kibana alerts notify the team.

Example searches

```
KQL: destination.domain : "bad-domain.xyz"

EQL: sequence by host.id with maxspan=5m
  [process where process.name == "powershell.exe"]
  [network where destination.domain == "bad-domain.xyz"]
```

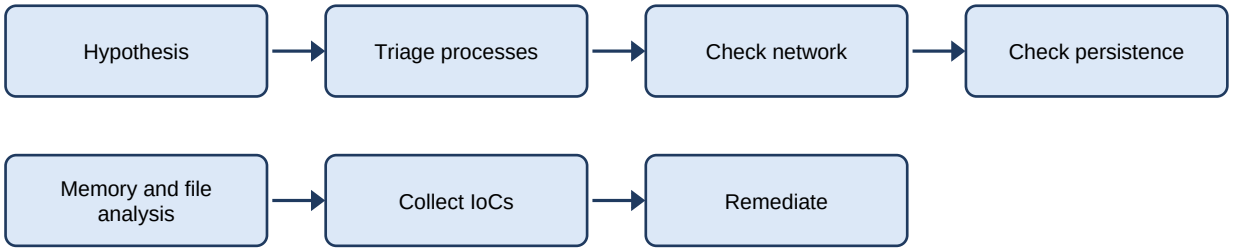
Unusual file activity is found with file-integrity events (new executables in temp folders, mass file renames). Findings are matched to the repeated suspicious-domain connections to identify the affected hosts, which are then isolated; saved searches and dashboards document the evidence.

Question 8: Threat Hunting for Malware Activities [5]

Scenario: no antivirus alert, but the workstation shows unusual CPU usage, unfamiliar processes and connections to unknown external IPs.

Idea. Antivirus relies on known signatures, so a hunter uses behaviour. Hypothesis: *"The workstation runs fileless or new malware (possibly a miner or RAT) with C2 communication."*

Hunting approach



Step	Action and commands	Suspicious sign
Processes and CPU	Process Explorer, *tasklist /svc*, Sysmon Event 1	Unsigned process, odd path (AppData, Temp), misspelt system name, high sustained CPU (cryptominer)

Step	Action and commands	Suspicious sign
Network	*netstat -ano*, TCPView, firewall and DNS logs	Connections to unknown IPs or rare ports, regular beacons
Persistence	Autoruns, *schtasks /query*, registry Run keys, services	New startup entries, tasks, WMI subscriptions
Memory and files	Volatility, hash and verify signature, sandbox the file	Injected code, packed binary, matching known family
Scope	Search SIEM/EDR for the same hash, domain and IP on other hosts	Other infected workstations

IoCs collected: file names, paths and SHA-256 hashes, C2 IPs/domains and ports, registry keys, mutexes, scheduled tasks and command lines.

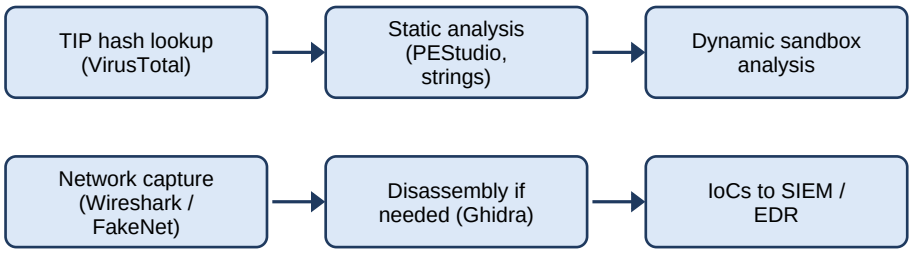
Remediation: isolate the workstation; kill the process and remove files and persistence; block IoCs on firewall, DNS and EDR; reset the user's passwords; re-image if the compromise is deep; patch software; deploy new EDR/SIEM detections; train the user on phishing; document the findings.

Question 9: Comparing Malware Analysis Tools Used in the IT Industry [5]

Scenario: the team must decide whether a suspicious file contains malicious code.

Category	Purpose	Examples	Usefulness / limitation
Static analysis tools	Inspect file without running: hashes, strings, headers, imports, disassembly	PEStudio, strings/FLOSS, Ghidra, IDA, YARA	+ Safe, quick triage, finds IoCs and code logic. - Fails against packing/obfuscation; no runtime view
Dynamic analysis tools	Run in sandbox and observe real behaviour	Cuckoo, any.run, Process Monitor, Regshot, Joe Sandbox	+ Shows file, registry, process and network actions even if packed. - Slower; malware may detect the sandbox
Network traffic analyzers	Capture and inspect traffic of the malware	Wireshark, Zeek, Suricata, Fiddler, FakeNet-NG	+ Reveals C2, protocols, exfiltrated data. - Encrypted traffic limits visibility
Threat intelligence platforms	Check reputation and context of hashes, IPs and domains	VirusTotal, MISP, OTX, MalwareBazaar	+ Fast identification of known malware and related IoCs. - Useless for new (zero-day) samples; depends on feed quality

Recommended combination



Start with threat intelligence and static analysis for fast and safe triage, run the sample in a sandbox with network capture to confirm behaviour, and use reverse engineering only for unclear or advanced samples. Finally, push the IoCs into SIEM and EDR for detection and containment. Using all four categories gives better accuracy than any single tool.

Question 10: Malware Analysis Report and Incident Response [5]

Scenario: an unfamiliar process, a modified system configuration and communication with a suspicious domain are found on an employee's computer.

Malware Analysis Report - outline

Section	Contents
1. Title and executive summary	Report ID, date, analyst, classification (TLP); short non-technical summary of the incident, impact and key recommendation
2. File information	File name, size, type, MD5/SHA-1/SHA-256 hashes, compile time, signature status, source (phishing email) and discovery time
3. Analysis methodology	Static analysis (strings, PE, imports), dynamic analysis in an isolated sandbox, network analysis, tools and versions used, environment
4. Observed behaviour	Process tree, files created/modified, system configuration changes, registry/persistence, network communication with the suspicious domain, mapped to MITRE ATT&CK
5. Indicators of Compromise	Hashes, file paths, registry keys, mutexes, domains, IPs, ports, User-Agent, YARA/Sigma rules
6. Threat intelligence findings	Malware family, campaign or actor, related IoCs, reliability and confidence of sources
7. Risk assessment	Likelihood and impact (confidentiality, integrity, availability), affected systems and data, overall rating, e.g. High
8. Containment actions	Isolate the host, block domain/IP/hash, disable and reset accounts, hunt for IoCs on other hosts
9. Eradication and recovery	Remove malware and persistence, restore the configuration, re-image or restore from clean backup, patch, verify with scans, monitor
10. Recommendations and lessons learned	Email filtering, MFA, least privilege, EDR/SIEM rules, user awareness training, update the IR playbook
11. Appendices	Screenshots, log extracts, timeline, full IoC list, references

The report follows the incident-response lifecycle (preparation, detection and analysis, containment, eradication, recovery, post-incident review) and gives both technical teams and management what they need to act.